

 CODEBASE AUDIT REPORT

ITS Platform Audit Report

Analisi completa di qualità, sicurezza, architettura e PWA



7.8 / 10

Voto complessivo

Piattaforma produzione-pronta con basi solide.
Alcuni punti di miglioramento noti non bloccanti.

DATA

26 aprile 2026

BRANCH

main

ULTIMO COMMIT

995250c

REVISORE

Claude Sonnet 4.6



Voto per area

Build & Qualità

A+

Build OK, TypeScript OK, ESLint OK, tutti i test passano

Architettura

A-

Multi-tenant solido, auth centralizzato, moduli ben separati

Sicurezza

B+

JWT validato, HMAC, rate limit presente ma in-memory

Dipendenze

B-

7 vulnerabilità alte, Next.js 16.2.2 → 16.2.3 non aggiornato

Test Coverage

B

33 unit test ok, 4 e2e spec presenti, no integration test DB

PWA

A

Manifest, SW, push VAPID, install prompt — tutto funzionante

1

Build & Qualità del Codice

A+



NEXT BUILD



TSC --NOEMIT



ESLINT .

33

UNIT TEST (TUTTI
PASSANO)

CHECK	RISULTATO	NOTE
next build	Exit 0	Nessun errore di compilazione
tsc --noEmit	Exit 0	Strict mode attivo, zero errori di tipo
eslint .	Exit 0	Nessun warning né errore
vitest run	5 file, 33 test	Tutti passano in 3.88s
E2E Playwright	Non eseguiti	Richiedono server live + credenziali

File più grandi (potenziale refactor futuro):

FILE	RIGHE	AREA
app/(app)/settings/bus-network/page.tsx	2807	UI configurazione rete bus
app/(app)/settings/pricing/page.tsx	2666	UI tariffario
app/(app)/piano-giorno/page.tsx	2361	UI piano operativo giornaliero
app/api/settings/bus-network/route.ts	2131	API rete bus

2 Architettura

A-

180

API ROUTES

155

MIGRAZIONI DB

62

MODULI SERVER-SIDE

113

ROUTE CON AUTH CENTRALIZZATO

COMPONENTE	TECNOLOGIA	NOTE
Framework	Next.js 16.2.2 App Router	TypeScript strict mode
Database	Supabase (PostgreSQL)	Multi-tenant via <code>memberships.tenant_id</code>
Auth	Supabase Auth + JWT	Wrapper centralizzato <code>authorizePricingRequest</code>
Email	Resend API	Centralizzato via <code>sendEmail()</code> / <code>resendFetch()</code>
Test unitari	Vitest 4.1.5	5 file, 33 test
E2E	Playwright 1.58.2	4 spec: scan, pdf-ops, pricing, smoke
PWA	SW custom + VAPID	Solo per sezione /driver
Notifiche push	Web Push API	VAPID keys, SLA alert con vibrazione

Pattern di autenticazione: `authorizeServiceRoleRequest()` valida il Bearer JWT tramite `admin.auth.getUser(token)`, recupera la membership, controlla ruolo + sospensione e registra audit log su ogni accesso negato. Il pattern è applicato a 113/180 route; le restanti usano token-based auth (link email firmati con JWT) o protezione via `CRON_SECRET`.

Controlli positivi rilevati durante l'analisi:

CONTROLLO	STATO	DETTAGLIO
JWT validato su API protette	OK	113 route, via Supabase <code>auth.getUser()</code>
WhatsApp webhook HMAC	OK	<code>createHmac</code> + <code>timingSafeEqual</code> da <code>crypto</code>
Cron jobs protetti	OK	<code>CRON_SECRET</code> su tutti i job schedulati
Link email firmati	OK	<code>verifyAgencyActionToken()</code> — JWT con scadenza
Rate limiting auth	OK	Register 10/h, OTP 3/h, reset 3/h + security alert email
Validazione input	OK	Zod schemas su tutti i body in ingresso
Multi-tenant isolation	OK	<code>tenant_id</code> su ogni query Supabase
SQL injection	OK	Supabase client usa query parametrizzate
Audit log	OK	Ogni accesso negato loggato con <code>userId</code> e route

Problemi rilevati:



Password di fallback hardcoded per autisti

Quando un autista non ha numero di telefono, la password diventa `"Ischia2025!"` — predicibile. Ha `force_password_change:true` come mitigante, ma la password iniziale è debole e nota.

`app/api/ops/departure-bus-assign/route.ts:97`



Rate limiting in-memory — non efficace su Vercel

Usa `Map<string, RateLimitEntry>` in-process. Su Vercel serverless ogni istanza ha memoria indipendente e il contatore si azzerà a ogni cold start. Il rate limit non funziona in produzione con più istanze concorrenti.

`lib/server/rate-limit.ts`



5 route admin con auth custom anziché il wrapper centralizzato

La logica è corretta ma non usa `authorizePricingRequest()`, quindi può divergere da aggiornamenti futuri del comportamento centrale.

`app/api/admin/agency-reviews/route.ts`, `fleet-reports/route.ts`, `tenant-settings/route.ts` ...

pnpm audit : 16 vulnerabilità — 1 bassa, 8 medie, 7 alte.

PACCHETTO	VERSIONE	SEVERITÀ	TIPO	FIX DISPONIBILE
next	16.2.2	Alta	DoS con Server Components	Sì → 16.2.3
xlsx	—	Alta x2	Prototype Pollution + ReDoS	Nessun patch ufficiale
flatted	—	Alta x2	Recursion DoS + Prototype Pollution (transitivo)	Sì → ≥3.4.2
picomatch	—	Alta x2	ReDoS via extglob (transitivo)	Sì → ≥2.3.2

**Next.js 16.2.2 → aggiornare a 16.2.3 immediatamente**

Vulnerabilità DoS attiva con Server Components. Un solo comando: `pnpm update next`. Rischio concreto in produzione.

`package.json` — "next": "^16.2.2"

5 Test Coverage

B

Unit test (Vitest) — 33/33 OK

FILE	AREA
<code>rate-limit.test.ts</code>	Sicurezza auth
<code>otp-utils.test.ts</code>	OTP generation/verify
<code>email-validation.test.ts</code>	Email domain check
<code>escape-html.test.ts</code>	XSS escaping
<code>admin-user-lookup.test.ts</code>	Admin lookup

E2E test (Playwright)

FILE	AREA
<code>smoke.spec.ts</code>	Login + navigazione base
<code>pricing.spec.ts</code>	Gestione tariffe
<code>pdf-ops.spec.ts</code>	Import PDF operativo
<code>scan.spec.ts</code>	Scan documenti



Nessun integration test con database reale

Le route API critiche (auto-assign, calcolo prezzi, creazione servizi) non sono coperte da test che tocchino il DB. I test unitari mockano le dipendenze esterne.

6 PWA (sezione /driver)

A

CHECK	STATO	DETTAGLIO
Manifest (/manifest.json)	OK	name, icons 192/512, start_url, display:standalone, shortcuts
Service Worker (/sw.js)	OK	Network-first, cache offline, push handler, SLA BroadcastChannel
Icone	OK	icon-192.png, icon-512.png, apple-touch-icon.png presenti
Registrazione SW	OK	<code>PwaInit</code> component nel layout /driver
Push notifications	OK	VAPID keys, subscribe/unsubscribe, SLA alert con vibrazione
Install prompt	OK	<code>beforeinstallprompt</code> intercettato, <code>triggerInstall()</code> esposto via context
Theme color	OK	<code>#0f172a</code> in viewport config + manifest
Offline fallback	OK	Pagina /driver in cache all'install del SW
Maskable icon safe-zone	Verifica	icon-512.png come maskable — safe-zone (40% centro) non verificata

7

Piano d'azione — Priorità

1

 Aggiorna Next.js 16.2.2 → 16.2.3**urgente**

Vulnerabilità DoS attiva con Server Components. `pnpm update next` + deploy. 5 minuti.

2

 Sostituisci la password fallback hardcoded con valore random

In `departure-bus-assign/route.ts:97` usa `crypto.randomBytes(8).toString('hex')` al posto di `"Ischia2025!"`.

3

 Sostituisci il rate limiter in-memory con Redis/Upstash

Non funziona su Vercel serverless multi-istanza. Upstash Redis ha piano gratuito, integrazione in meno di 1 ora.

4

 Unifica auth nelle 5 route admin con auth custom

Usa `authorizePricingRequest()` in `admin/agency-reviews`, `fleet-reports`, `tenant-settings` per consistenza futura.

5

 Valuta alternativa a `xlsx` (nessun patch ufficiale disponibile)

Le vulnerabilità Prototype Pollution e ReDoS di `xlsx` non hanno patch. Considera `exceljs` se l'input proviene da utenti.

6

 Aggiungi integration test per le route API critiche

Auto-assign, calcolo prezzi, creazione servizi — test con Supabase locale (`supabase start` + Vitest con client reale).

7

 Verifica safe-zone icona PWA maskable

Genera una variante dell'icona con padding per la safe-zone 40% centrale su launcher circolari Android.

8

 Considera il refactor dei 4 file con +2000 righe

Non bloccante. `bus-network/page.tsx` (2807 righe), `pricing/page.tsx` (2666) — suddivisione in sotto-componenti per migliore manutenibilità.